

SIH 2026 · PROBLEM STATEMENT 26164 · TECHNICAL PRESENTATION SCRIPT

Blindspot ECDAT

Enterprise Cryptographic Discovery & Analysis Tool

Elevator: You cannot migrate cryptography you cannot find.

Runtime: ~8 minutes (extend/trim per Q&A budget)

Stack: React 19 · TypeScript · Tailwind CSS v4 · FastAPI · Python 3.13 · Pydantic v2 · Semgrep · CycloneDX 1.6 · Firebase · Vercel · Railway

S1 Opening & hook · 20 s

Good morning. Team [name]. We are presenting **Blindspot ECDAT** — Enterprise Cryptographic Discovery and Analysis Tool — our solution to Problem Statement **26164**, comprehensive **CBOM analytics**. Our thesis is one line: **you cannot migrate cryptography you cannot find**.

S2 Threat model & problem framing · 45 s

Post-quantum cryptography — **PQC** — is not academic. **Shor's algorithm** on a Cryptographically Relevant Quantum Computer, a **CRQC**, breaks **RSA**, **ECDH**, **ECDSA**, and **Diffie-Hellman** outright. **Grover's algorithm** halves the effective security of symmetric primitives — **AES**, **SHA-2**, **HMAC**. The concrete threat today is **HNDL** — **Harvest Now, Decrypt Later** — any confidential ciphertext an attacker captures now becomes plaintext the moment a CRQC exists. NIST has standardised **ML-KEM** under **FIPS 203** for key encapsulation, and **ML-DSA** under **FIPS 204** for digital signatures. The bottleneck is not the algorithms — it is discovering where classical cryptography is used across code, dependencies, containers, binaries, infrastructure-as-code, and live network endpoints. That gap is what ECDAT closes.

S3 Architecture overview · 45 s

ECDAT is a production-grade full-stack application. **Frontend:** React 19 with TypeScript, Tailwind CSS v4, Recharts, built with Vite, deployed to Vercel. **Backend:** FastAPI on Python 3.13, Pydantic v2 for schema validation, Uvicorn as the ASGI server, deployed to Railway. **Identity:** Firebase Auth — ID tokens verified server-side with `check_revoked=True`. **Persistence:** Firestore for scan and finding metadata, Firebase Cloud Storage for CBOM artefacts. **Discovery engine:** Semgrep for AST-level source analysis, Python's `ssl` and `cryptography` libraries for TLS handshake and X.509 parsing, host container CLIs — Docker, Podman, or Nerdctl — for image acquisition. **Test coverage:** 283 backend tests, 18 frontend tests, all green.

S4 The seven-stage pipeline · 90 s

The pipeline is **deterministic**: identical inputs always produce identical outputs. Every stage consumes a single **normalised finding contract**, so a new discovery source plugs in without touching downstream analysis.

Stage 1 · Discover. Six independent scanners across six surfaces (detailed next slide).

Stage 2 · Evidence. Every finding carries `filePath`, `lineNumber`, `codeSnippet`, `detectionMethod`, and a **confidence score** banded into `high` / `medium` / `low`.

Stage 3 · CBOM generation. Each finding becomes a **CycloneDX 1.6** cryptographic-asset component — schema-validated JSON, carrying `algorithm`, `primitive`, `parameterSetIdentifier`, `mode`, `OID`, and evidence occurrences.

Stage 4 · Classify. Artefact type, security goal — confidentiality, authenticity, or integrity — data-lifetime **X** in years drawn from a usage-keyed policy table, criticality, and a `isLongLivedTrustAnchor` flag for root-CA and code-signing keys.

Stage 5 · Risk. Mosca's inequality: $X + Y > Z$. **X** is data lifetime, **Y** is organisational migration time, **Z** is the quantum horizon. Sum exceeds **Z** → **Overdue**; between **Z/2** and **Z** → **Transitional**; below → **Low-risk**. **Z** is configurable; every result carries its provenance in `zSource`.

Stage 6 · Recommend. Deterministic strategy — `PQC` / `HYBRID` / `DEFER` / `REMEDIATE_NOW` / `INVESTIGATE`. Target is **usage-aware**: RSA for key establishment → ML-KEM; RSA for signatures → ML-DSA. Each PQC recommendation carries a **CostProfile** — public-key, ciphertext, signature, and private-key sizes in bytes, cited to FIPS 203 / 204. **Published sizes, never fabricated latency.**

Stage 7 · Plan. A five-wave migration roadmap: Immediate Remediation, Wave 1 PQC, Wave 2 Hybrid, Wave 3 Monitor, Investigate. Priority score = `tierWeight × 100 + criticalityWeight × 10 + blastRadius`, where blast radius is the co-located crypto count as a change-impact proxy.

S5 Six discovery surfaces · 90 s

1 • Source code. Semgrep AST rules for Python and OpenSSL-style C. Detects RSA, ECC, DH, AES, DES, MD5, SHA-1 with parameter resolution via AST inspection. Detection method:

`semgrep_ast_confirmed`.

2 • Dependency manifests. `requirements.txt` parser flagging crypto-providing packages — `pycryptodome`, `cryptography`, and equivalents. Detection method: `dependency_manifest`.

3 • Container images. Host CLI — Docker, Podman, or Nerdctl — `image inspect` to check the local cache, `image pull` if missing, `image save` to produce a tarball. Layers flatten into a temporary rootfs on the project volume — never `%TEMP%`, which conflicts with Windows Defender. Extraction is defended: **zip-slip / path-traversal**, **symlink escape**, and **decompression-bomb** guards. Source and dependency scanners then run against the rootfs unchanged.

4 • Compiled binaries. Fingerprint match against **SHA-256's eight H0 initial hash values**, SHA-1's five words, MD5's four little-endian words — endian layout **disambiguates SHA-1 from MD5** — AES S-box bytes, ASN.1 OIDs including `1.2.840.113549.1.1.1` (`rsaEncryption`), and library brand strings for OpenSSL, wolfSSL, mbedTLS, libsodium, BoringSSL. Every binary finding is **deliberately low-confidence**, auto-routed to `needsVerification`. Detection method: `binary_signature`.

5 • HSM and KMS declarations. Terraform (`.tf`), CloudFormation (`.yaml`), Kubernetes manifests, PKCS#11 configs, and SDK-client code. Recognises **AWS KMS**, **GCP KMS**, **Azure Key Vault**, **AWS CloudHSM**, Azure Dedicated HSM, SoftHSM, YubiHSM, SafeNet Luna, Entrust nShield, PyKCS11. Labelled **declared, not attested**. When Terraform declares `key_spec = "RSA_2048"`, we resolve the algorithm; otherwise the finding routes to `INVESTIGATE`. Detection method:

`infra_declaration`.

6 • Live TLS / certificates. Standard-library socket handshake reads peer certificate — issuer, subject, key type, key bits, curve, signature algorithm, expiry — plus negotiated protocol and cipher suite. The certificate's public-key algorithm runs through the same `classify` → `risk` → `recommend` chain. **SSRF-guarded**: hostname resolves to a public address, private, loopback, link-local, and reserved ranges are refused. Detection method: `tls_probe`.

S6 Analytical depth · 60 s

Beyond scanning, three analytical features earn ECDAT its *analytics tool* label.

Compliance sensitivity. Seven named Z presets: India CII Category A 2027, B 2028, C 2029; NIST IR 8547 2030 deprecation, 2035 disallow; mid-range CRQC estimate; demo default. The *same finding* re-tiers as Z changes. Under a 15-year CRQC estimate, RSA-2048 with X + Y equal to eight years is **Low-risk**; under India's 2027 Category A deadline where Z collapses to one year, the same finding is **Overdue**. Policy dependency is made visible, not hidden.

HNDL exposure flag. Derived from three fields — security goal is confidentiality; quantum threat is `SHOR_BREAKS` ; Mosca tier is Overdue. Confidentiality + Shor-breakable + overdue = harvest-now-decrypt-later. Nothing new asserted; three real fields combined honestly.

Needs-verification flag. True when detection confidence is low or `parameterStatus` is `unresolved` . Surfaces uncertainty rather than hiding it. Dashboard count and per-row badges on the findings table.

S7 Security hardening · 45 s

Every user input is treated as untrusted. **Fail-closed auth:** `AUTH_DISABLED` is honoured only when `BLINDSPOT_ENV` is the literal string `development` ; the default is `production` . Firebase ID tokens are verified with `check_revoked=True` . **SSRF guards:** repository-URL scanning is HTTPS-only, host-allowlisted, and rejects IP literals plus `localhost` / `.local` / `.internal` ; TLS scan rejects private, loopback, and reserved ranges. Container extraction has **zip-slip**, **symlink escape**, and **decompression-bomb** guards with byte and file-count budgets. Scan endpoint enforces a **single-flight** `asyncio.Lock` — HTTP 429 on overlap. The pipeline runs in a thread pool via `asyncio.to_thread` so it never blocks the event loop. **GET endpoints are scoped to the scan owner** — findings, roadmap, compliance, CBOM export return 404 to non-owners. **CSV export neutralises formula injection.** Error responses are generic — absolute paths never leak to the client.

S8 Deliverables vs PS 26164 · 40 s

Against the problem statement's **seven artefact types** — algorithms, keys, certificates, protocols, libraries, hardware modules, cloud services — we cover **seven of seven**, with hardware modules and cloud services labelled *declared, not attested*. Against the **four scan targets** — source, libraries, binaries, container images — we cover **four of four**. We produce a schema-valid **CycloneDX 1.6 CBOM**. We provide an interactive GUI with dashboard, findings table with sticky-header scroll, finding-detail with a visible evidence → classification → Mosca → recommendation chain, CBOM viewer, migration roadmap, compliance sensitivity, and a live TLS scan page. Every claim on screen maps to code in the repository.

PS-MANDATED OUTCOME	BLINDSPOT COVERAGE
Catalogue algorithms, keys, certs, protocols, libraries, HSMs, cloud services	7 of 7 — HSM/KMS labelled <i>declared, not attested</i>
Quantum risk assessment via structured framework	Mosca $X + Y > Z$, seven configurable Z presets
Classify by type, lifetime, criticality, quantum risk	Full — usage-keyed policy tables, security-goal split
PQC / Hybrid recommendations by risk, latency, cost	Deterministic; cost expressed as FIPS 203/204 byte sizes
Scan source, binaries, libraries, container images	4 of 4 scan targets, plus live TLS as bonus surface
Report in standardised format	CycloneDX 1.6 <code>cryptographic-asset</code>
Interactive GUI to visualise the scan, risks, and results	Full application with 7 primary pages

S9 Honesty as differentiator · 30 s

Our unique property is what we *do not* do. We never fabricate numbers. **CostProfile** cites FIPS 203 and FIPS 204 byte sizes, never measured latency. **Z provenance** travels with every Mosca result. Findings carry explicit provenance labels — `semgrep_ast_confirmed`, `dependency_manifest`, `binary_signature` (low, verify), `infra_declaration` (declared, not attested), `tls_probe`, `cached`. Uncertain findings surface through `needsVerification`. When we do not attest a capability — HSM or cloud KMS internal state — we say so. That intellectual honesty is our differentiator.

S10 Close · 15 s

To close: Blindspot ECDAT scans **six discovery surfaces**, produces a **CycloneDX CBOM**, runs **Mosca's inequality** against real regulatory horizons, recommends **NIST PQC targets** with sourced sizes, and sequences it all into a **five-wave migration roadmap**. **Two hundred and eighty-three backend tests. Zero fabricated data.** You cannot migrate cryptography you cannot find. Thank you.

Appendix A · Term & acronym glossary — one line each

CRYPTOGRAPHY & STANDARDS

PQC	Post-Quantum Cryptography — algorithms resistant to quantum attack.
CRQC	Cryptographically Relevant Quantum Computer — hypothetical device that runs Shor at scale.
Shor	Quantum algorithm that breaks RSA, ECDH, ECDSA, DSA, and Diffie-Hellman.
Grover	Quantum search algorithm that halves symmetric-key effective strength.
HNDL / SNDL	Harvest-Now-Decrypt-Later — capture ciphertext today, decrypt post-CRQC.
RSA	Rivest–Shamir–Adleman public-key algorithm — broken by Shor.
ECDH / ECDSA	Elliptic-Curve Diffie-Hellman / Digital Signature Algorithm — broken by Shor.
DH	Classical Diffie-Hellman key exchange — broken by Shor.
AES	Advanced Encryption Standard — symmetric block cipher; Grover halves effective bits.
SHA-2 / SHA-1 / MD5	Hash families; SHA-1 and MD5 are collision-broken today.
ML-KEM	Module-Lattice-Based Key Encapsulation Mechanism (FIPS 203). Successor to RSA-KEM / ECDH.
ML-DSA	Module-Lattice Digital Signature Algorithm (FIPS 204). Successor to ECDSA / RSA-PSS.
FIPS 203 / 204	NIST Federal Information Processing Standards for ML-KEM and ML-DSA.
NIST IR 8547	NIST transition plan: deprecate classical PKC by 2030, disallow by 2035.
India CII (MeitY)	Categorised PQC deadlines: A → 2027, B → 2028, C → 2029.
Hybrid crypto	Classical + PQC in the same handshake or signature for transition safety.
OID	Object Identifier — ASN.1 dotted-decimal identifier for a crypto primitive.
HSM	Hardware Security Module — tamper-resistant crypto device (Luna, nShield, YubiHSM).
KMS	Key Management Service — cloud crypto service (AWS/GCP/Azure).
PKCS#11	Vendor-neutral C API for talking to HSMs / cryptographic tokens.
SoftHSM / YubiHSM / Luna / nShield	PKCS#11 modules — software, USB, and rack HSMs.

BLINDSPOT CONCEPTS

CBOM	Cryptographic Bill of Materials — inventory of every crypto asset.
CycloneDX 1.6	OWASP-standardised BOM schema; supports cryptographic-asset components.
Mosca's inequality	$X + Y > Z$; X = data lifetime, Y = migration time, Z = quantum horizon.

Overdue / Transitional / Low-risk	Three Mosca tiers assigned per finding.
CostProfile	Public-key, ciphertext, signature, private-key sizes in bytes (FIPS 203/204 sourced).
Blast radius	Co-located crypto count per file — change-impact proxy in the roadmap.
Wave 1 / 2 / 3	PQC / Hybrid / Monitor migration waves in the roadmap.
needsVerification	Flag: low detection confidence <i>or</i> unresolved parameter.
Provenance labels	Every finding tagged with how it was found: AST, manifest, fingerprint, declaration, TLS probe.

TECH STACK

FastAPI	Async Python web framework used for the backend API.
Pydantic v2	Data-validation library used for models with alias-generated camelCase output.
Uvicorn	ASGI server hosting FastAPI in dev and prod.
Semgrep	Open-source AST-level static analyser; drives source scanning.
React 19 / TypeScript	Frontend framework and type system.
Tailwind CSS v4	Utility-first CSS with design tokens; no external UI kit.
Vite	Frontend build tool + dev server.
Recharts	Composable React charting library used on the dashboard.
Firebase Auth	Identity provider; backend verifies ID tokens with <code>check_revoked=True</code> .
Firestore	Serverless NoSQL DB storing scan and finding metadata.
Cloud Storage	Firebase object store for CBOM JSON and findings JSON.
Vercel / Railway	Frontend and backend hosting respectively.
Docker / Podman / Nerdctl	Container CLIs; any of the three drives image pull + save.
Terraform / CloudFormation	Infrastructure-as-Code declaration formats scanned for HSM/KMS references.
Kubernetes / SealedSecret / ExternalSecret	K8s secret-management resources referring to a KMS backend.

SECURITY TERMS

SSRF	Server-Side Request Forgery — mitigated by allowlist + IP-literal + private-range rejection.
Zip-slip	Path-traversal via tar/zip entries with <code>../</code> — guarded during image extraction.
Decompression bomb	Small archive that expands to gigabytes — mitigated with byte and file budgets.
CSV formula injection	Cells starting with = + - @ executing in spreadsheets — neutralised in exports.

Fail-closed	Missing config defaults to the safe state (auth enforced).
Single-flight lock	<code>asyncio.Lock</code> ensures only one scan runs at a time; overlap → HTTP 429.
Owner-scoped store	GET endpoints refuse to serve one user's scan to another user.

Appendix B · Q&A ammunition (one-line answers)

Why Semgrep and not pure regex?

AST-level matching resolves

`RSA.generate(2048)` even when the argument is a named variable, and it is language-aware — false positives from strings and comments are eliminated.

Why CycloneDX and not SPDX?

CycloneDX 1.6 is the only widely adopted BOM standard that natively models cryptographic assets via `cryptographic-asset` components.

Why is Z a configuration parameter?

Because it is an assumption, not a fact. We honour that by making it configurable and shipping seven named regulatory presets, each with a provenance string.

Why fingerprint binaries at low confidence?

Because seeing OpenSSL S-box bytes in a binary tells you what is *linked*, not what is *used*. Full disassembly is out of scope; the current design surfaces uncertainty.

Why call HSM/KMS coverage “declared, not attested”?

Live attestation requires vendor SDKs and credentials — out of scope for a hackathon. Declaration scanning is real, provable coverage that lays a clear upgrade path.

How is HNDL exposure computed?

Three real fields combined: `securityGoal == confidentiality ^ quantumRisk == SHOR_BREAKS ^ riskTier == overdue`.

How do you avoid claiming fake latency?

`CostProfile` contains *bytes* — `publicKeyBytes`, `ciphertextBytes`, `signatureBytes` — sourced from FIPS 203/204. The word “latency” never appears in output.

What if Firebase is down?

The pipeline is designed best-effort for cloud persistence. Findings are served from an in-memory owner-scoped store; local artefacts are still written to disk.

Cloud vs air-gap?

Cloud-native deployment for the demo; the backend is a single container so it also runs on-prem without change. No external network calls beyond user-supplied targets.

What is the minimum config to reproduce?

Python 3.10+, Node 20+, Semgrep CLI on PATH, git; optionally a container CLI for image scans. Any Linux/macOS/Windows dev machine.

Appendix C · Live demo cues (if judges ask “show it running”)

Cue 1 · Discover. Open `/scan` . Toggle Container Image. Type `python:3.11-slim` → **Start Discovery Scan**. Backend log shows `image pull → save → extract → semgrep → findings` .

Cue 2 · Evidence. On `/findings` , click any RSA row. Left column: file, line, code snippet. Detection method: `semgrep_ast_confirmed` , confidence `high` .

Cue 3 · Mosca. Scroll the finding detail to **Stage 03 · Mosca risk**. Read $X + Y > Z$; point to the overdue overflow bar; call out `zSource` .

Cue 4 · Cost. Below Mosca, the Recommendation card has a **Cost & Size Profile**. Read the public-key bytes, cite FIPS 203.

Cue 5 · Compliance sensitivity. Open `/compliance` . Click **India CII 2027**. Overdue jumps from 5 to 8. Point at the delta chip.

Cue 6 · Roadmap. Open `/roadmap` . Five waves visible on the top strip. Click Wave 1 → priority-ranked items with cost bands.

Cue 7 · TLS. Open `/tls` . Scan `github.com` . TLSv1.3, ECDSA-P256 cert → `overdue` → ML-DSA-65.

Blindspot ECDAT — SIH 2026 · PS 26164 · Enterprise Cryptographic Discovery & Analysis Tool. Every claim in this script maps to code in the repository under `backend/app/` and `frontend/src/` . Test suite: 283 backend, 18 frontend, all green.